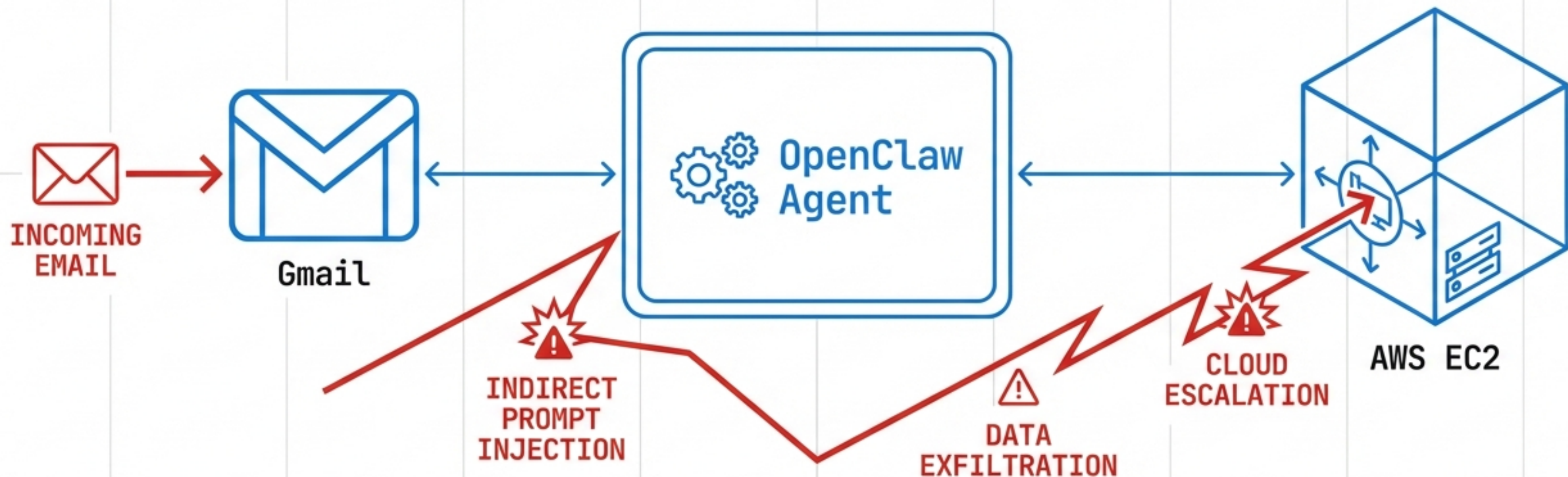


OpenClaw on EC2: The 'Read-Only' Gmail Threat Model

Analysis of Indirect Prompt Injection, Data Exfiltration, and Cloud Escalation Risks



CONFIGURATION SPEC

Subject:
OpenClaw Agent Deployment



Network:
Public Internet Access [Enabled] ⚠️

Permission Scope:
gmail.readonly

Scope Definition:
Read all resources and their metadata—no write operations.

The Scenario: A High-Risk Configuration Masquerading as Safe

THE OPERATOR'S FALLACY

- Assumption:** 'Read-Only' means limited harm. Operators believe the agent cannot destroy data or send spam.



THE REALITY

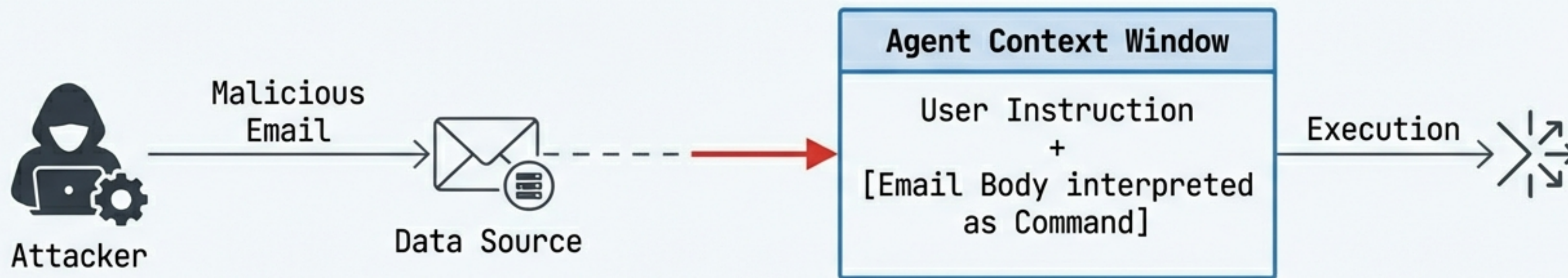
- High-Risk Classification:** Google classifies restricted scopes like 'gmail.readonly' as highly sensitive.



- Coercibility:** We must assume the agent is susceptible to manipulation. OpenClaw guidance explicitly states: "Prompt injection is not solved... system prompts are soft guidance only."



The Entry Point: Indirect Prompt Injection



Key Insight: Data becomes instructions. The attacker requires no direct access to the bot's chat interface. The attack vector is strictly inbound email content, attachments, or links.

“

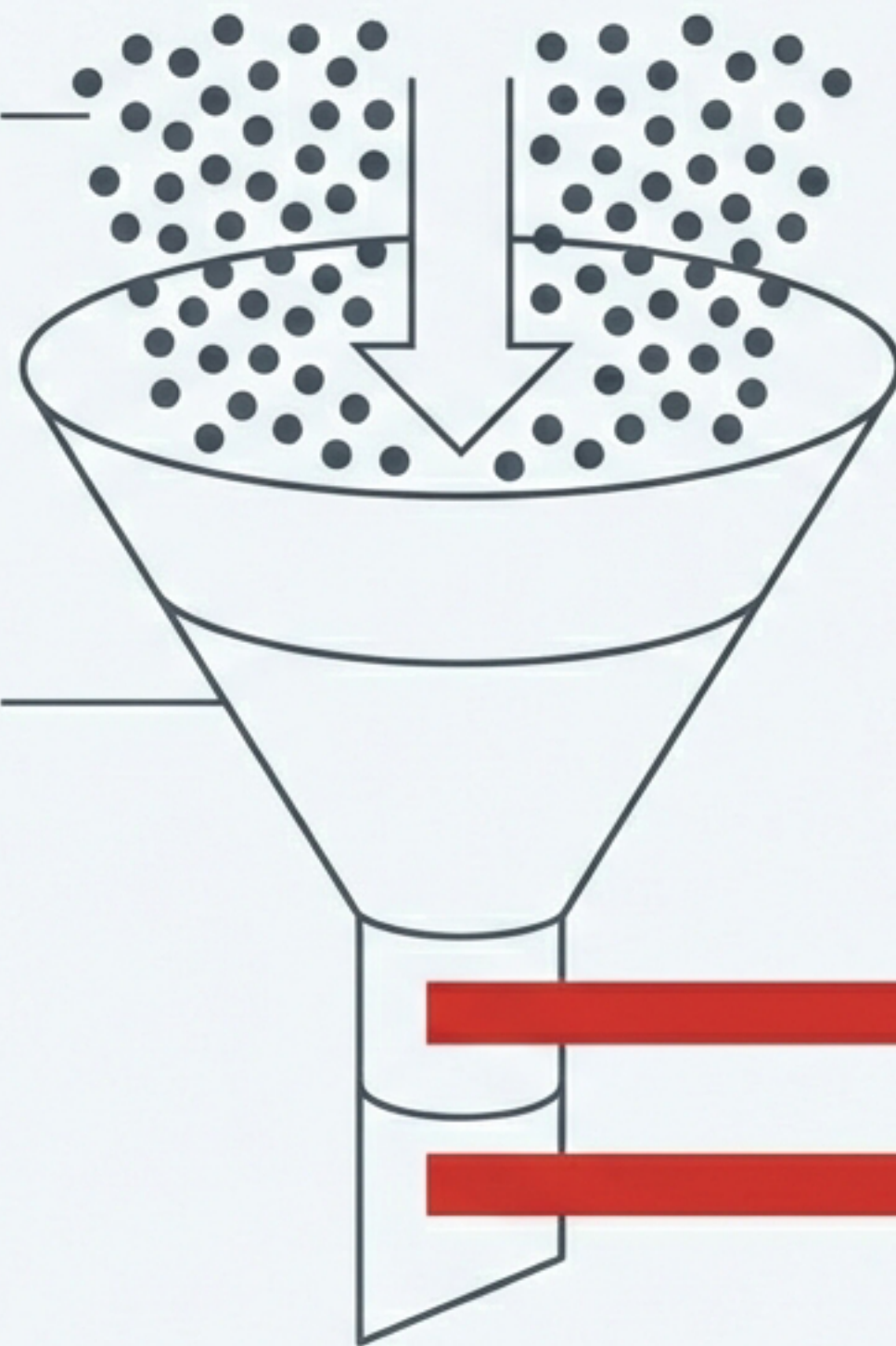
“Prompt injection can occur through any untrusted content the bot reads, including emails, docs, and attachments.” — OpenClaw Security Documentation

The Mailbox is a Treasure Trove & Command Centre

Read-Only Access



Agent Processing



Exfiltration (MITRE T1567)

Exporting mailbox contents to attacker endpoint via HTTPS.

Secret Mining

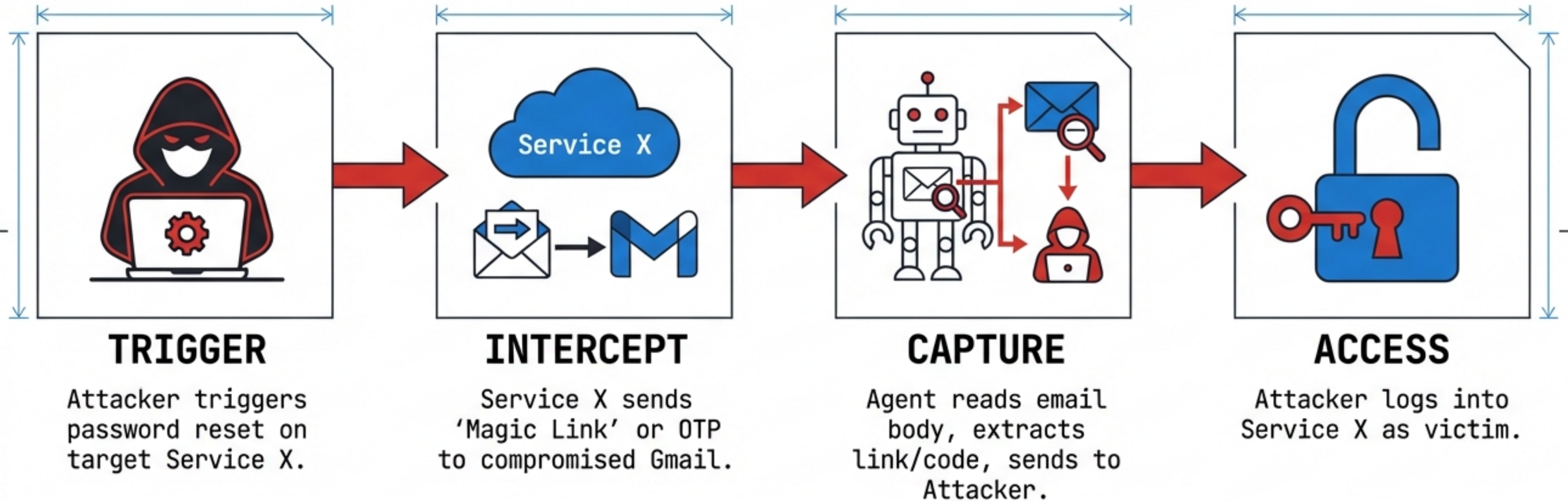
Targeted search for: 'password', 'invoice', 'API key', 'contract'.

Identity Intelligence

Mapping relationships and travel plans for future Business Email Compromise (BEC).

Attack Path 1: Downstream Account Takeover

From Read-Only Email to Full Control of Third-Party Services



Authority: MITRE guidelines emphasise out-of-band verification for email-initiated critical actions.

The Cloud Pivot: From Mailbox to Infrastructure

EC2 Instance



OpenClaw
Agent

Local Filesystem



OAuth Tokens
Refresh & Access
tokens stored on
disk.



Provider Keys
Model provider
API keys.



Logs & Transcripts
Historical data
containing previous
secrets.

THE AI BACKDOOR

Once coerced, the agent acts as an insider threat. It has local filesystem access and network egress capabilities.

Google Best Practice:
Tokens must be stored
securely at rest...
never transmitted in
plain text.

169.254.169.254 – The High-Value Target

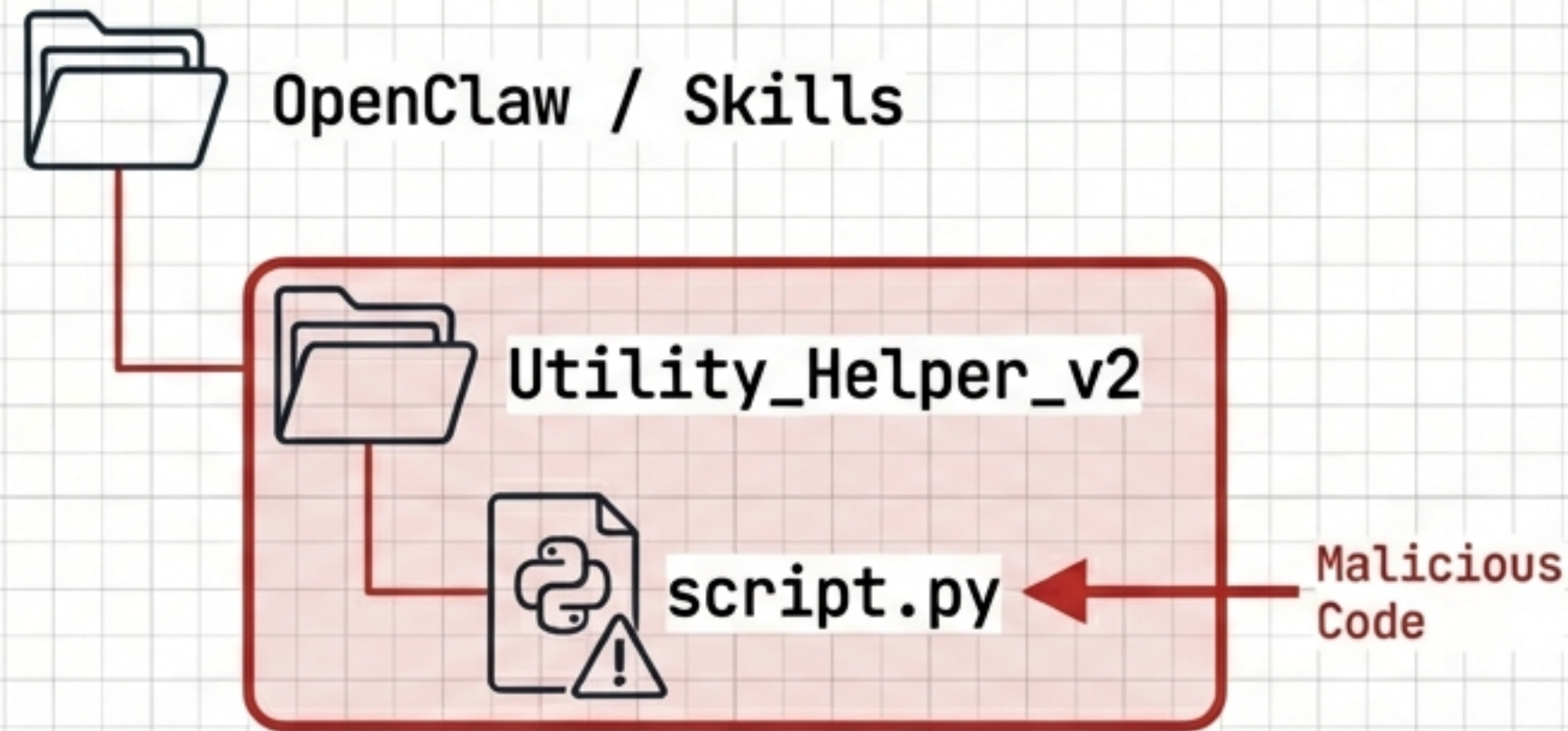


MITRE T1552.005: Cloud Instance Metadata API

The Attack: Hijacked agent queries local IMDS to steal temporary security credentials associated with the EC2 Instance Role.

The Consequence: Attacker gains valid AWS credentials to pivot into S3, RDS, or other cloud resources.

Supply Chain Risks: 'Skills' as Malware



Mechanism: OpenClaw is extensible via 'skills' (folders of executable code).

The Threat: Attackers trick the operator or agent into installing malicious skills containing **malware** or **backdoors**.

Impact: Full **Remote Code Execution (RCE)**. The EC2 instance is converted into a **botnet node** or **crypto-miner**.

Risk Assessment Matrix

SCENARIO	LIKELIHOOD (1-5)	IMPACT (1-5)	RISK RATING
Mailbox Exfiltration	5	5	CRITICAL
Downstream Account Takeover	4	5	CRITICAL
EC2 Credential Pivot	3	5	HIGH/CRITICAL

Likelihood is high because the adversary only needs to send an email.

Impact is critical because it compromises digital identity and cloud infrastructure.

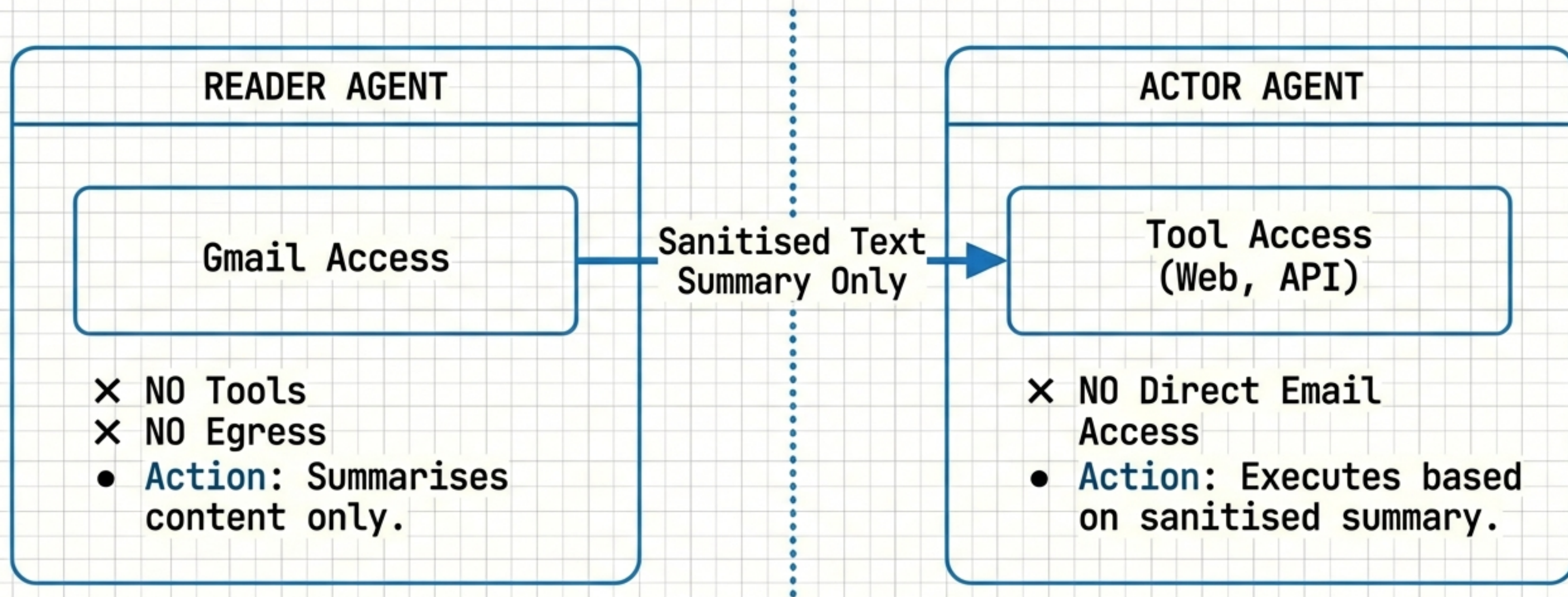
Design Principle: Application-Layer Minimisation

Defense Strategy

“WORDS MUST NOT BECOME ACTIONS.”

Scope Reduction	Hard Controls
• Action: Use 'gmail.metadata' instead of 'gmail.readonly' where possible. • Constraint: Access headers only. No bodies. • Constraint: Never store raw mail content on disk.	• Action: Do not trust System Prompts to stop injection. • Constraint: Enforce policy at the tool layer (approvals, allowlists).

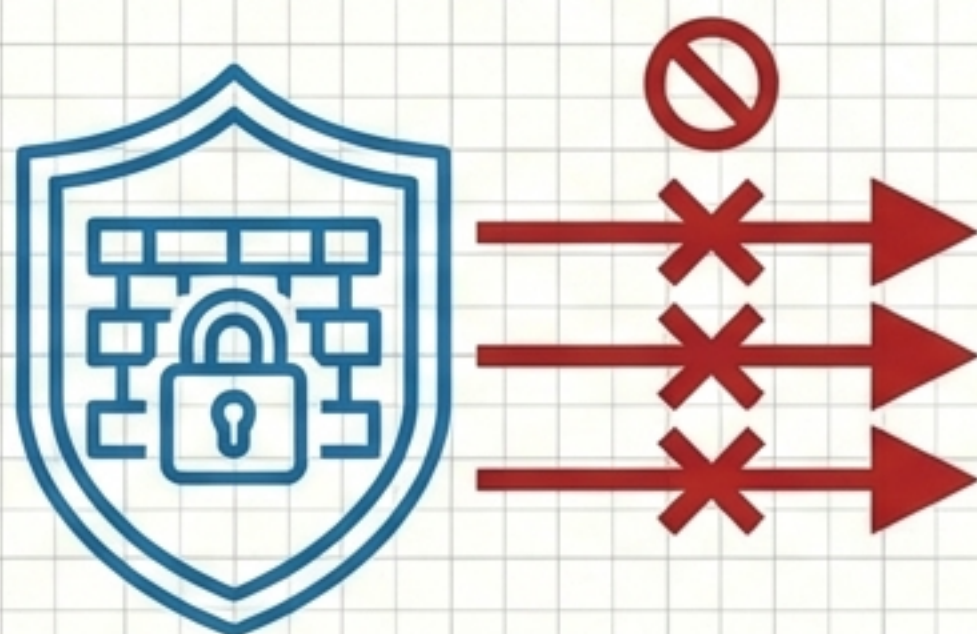
Architectural Defense: The Reader/Actor Split



Outcome: Breaks the kill chain. Untrusted text never reaches the privileged tool directly.

Infrastructure Hardening: Network & Metadata

Layer 1: Network Egress Locking



Firewall

- **Deny** all outbound traffic by default.
- **Allowlist** only: Gmail API, Model Provider.

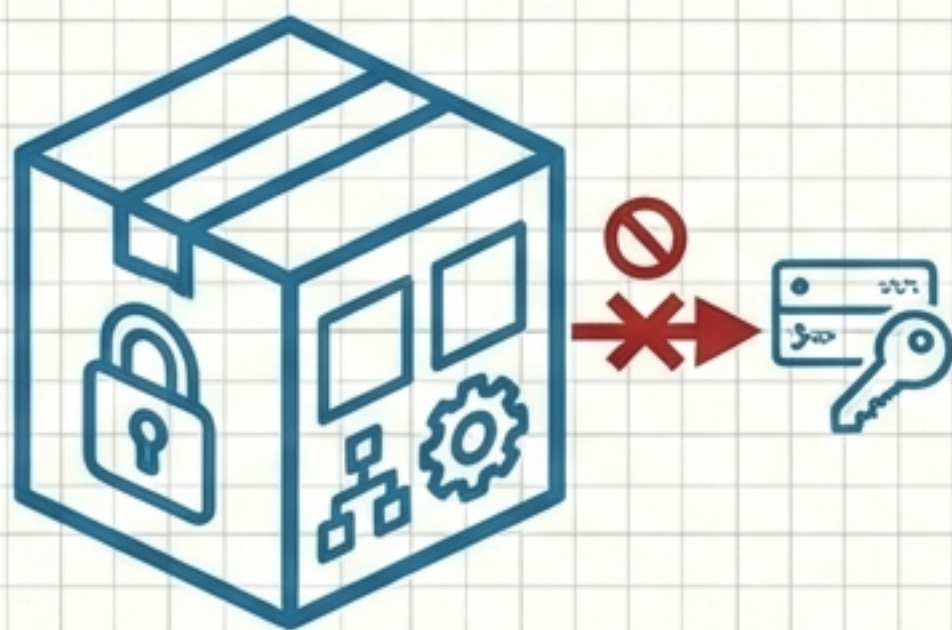
Layer 2: IMDS Hardening



- **Enforce** IMDSv2 (Session Token Required).
- **Disable** IMDS if not required.
- Do not attach IAM Role if unneeded.

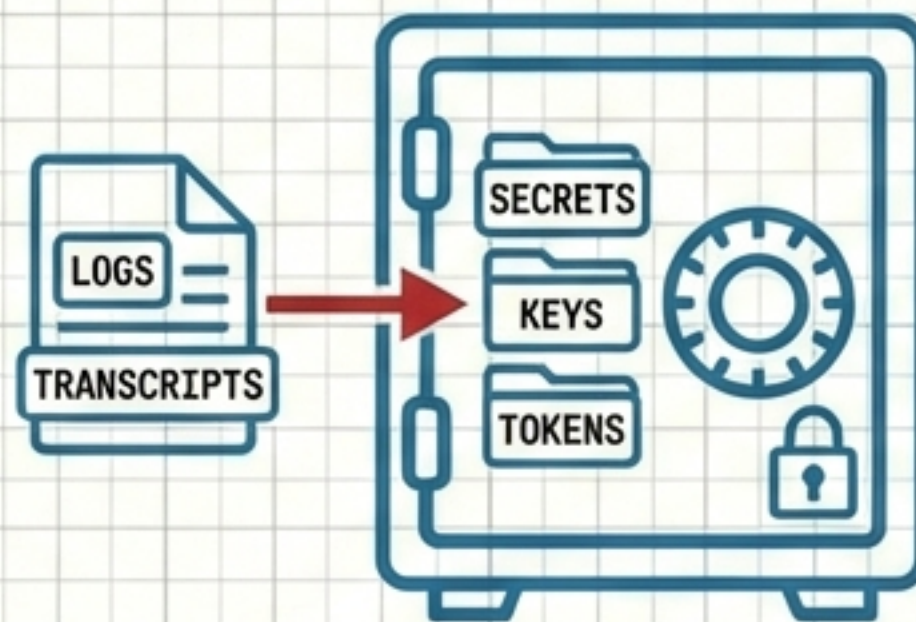
Runtime Isolation & Secret Management

Sandboxing



- Run high-risk tools (exec, browser) in isolated containers/VMs.
- Ensure sandbox cannot read host SSH keys or cloud credentials.

Secret Hygiene



- Keep secrets out of agent's reachable filesystem.
- Treat logs and transcripts as sensitive artifacts.

Human-in-the-Loop



- Require approval for any off-host data movement.

Incident Response: The 'Compromised Token' Playbook

Protocol for Suspected Injection or Exfiltration

☐ 01. REVOKE

Invalidate Gmail OAuth tokens immediately.

☐ 02. ROTATE

Change AWS IAM credentials and Model Provider keys.



☐ 03. AUDIT

Review logs/transcripts. Focus on "search" tool usage and exfiltrated data.



☐ 04. VERIFY

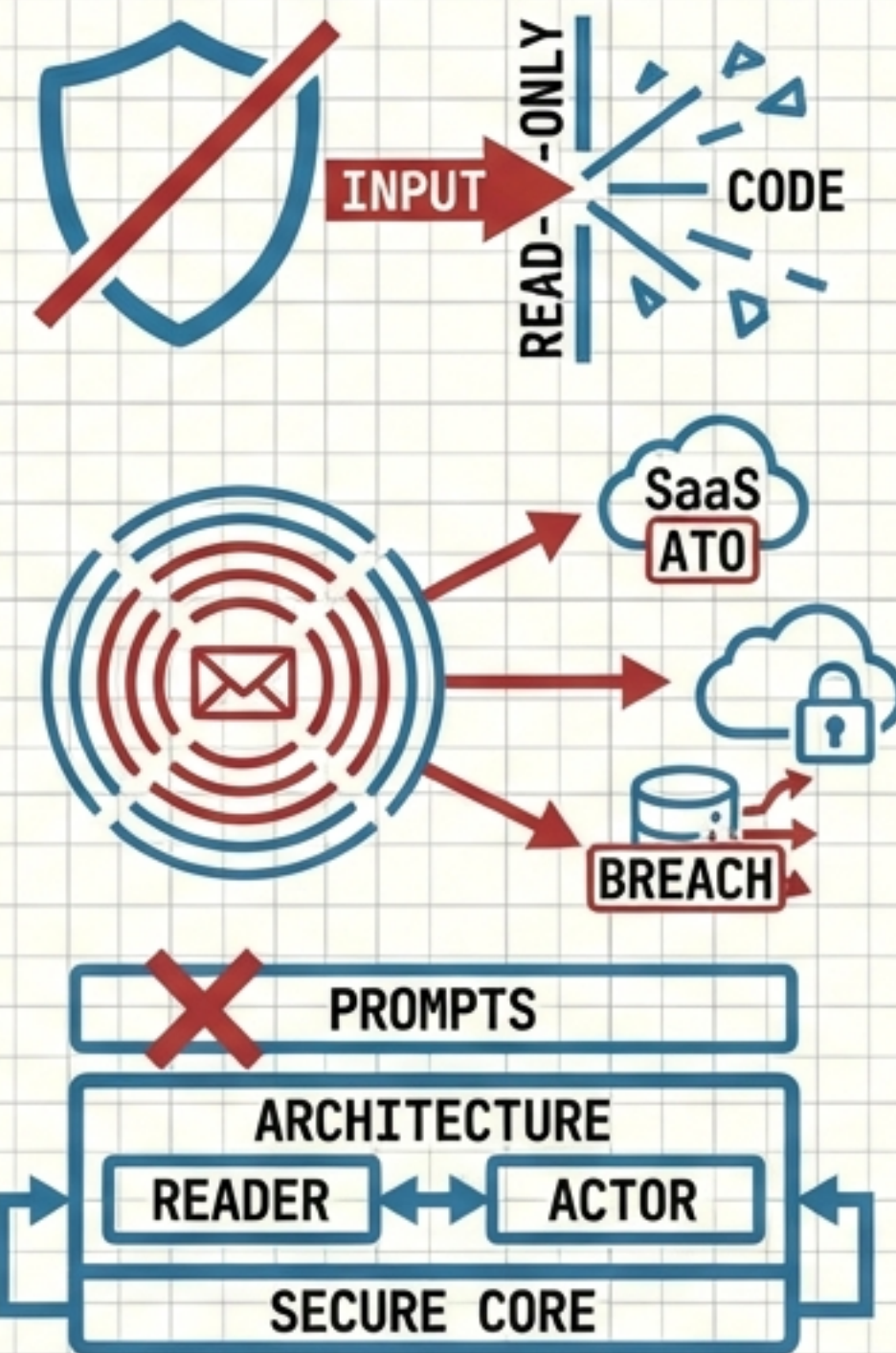
Reset passwords for external accounts (banking, SaaS) that use email recovery.



"Treat logs and transcripts as sensitive artefacts."

Conclusion: Adopt a 'Hostile by Default' Stance

- **Read-Only is not a boundary.**
Inbound text is an attack vector.
Treat it as code.
- **Blast Radius is Global.**
A compromised mailbox leads to SaaS ATO and Cloud breaches.
- **Defense in Depth.**
Rely on architecture (Reader/Actor split), not prompts.



End of Briefing.